Protecting RHG

IT Security

Agenda

00 | Introduction & Context

01 | Strategy and Governance

02 | Cybersecurity Functions & Services

03 | Cybersecurity Controls

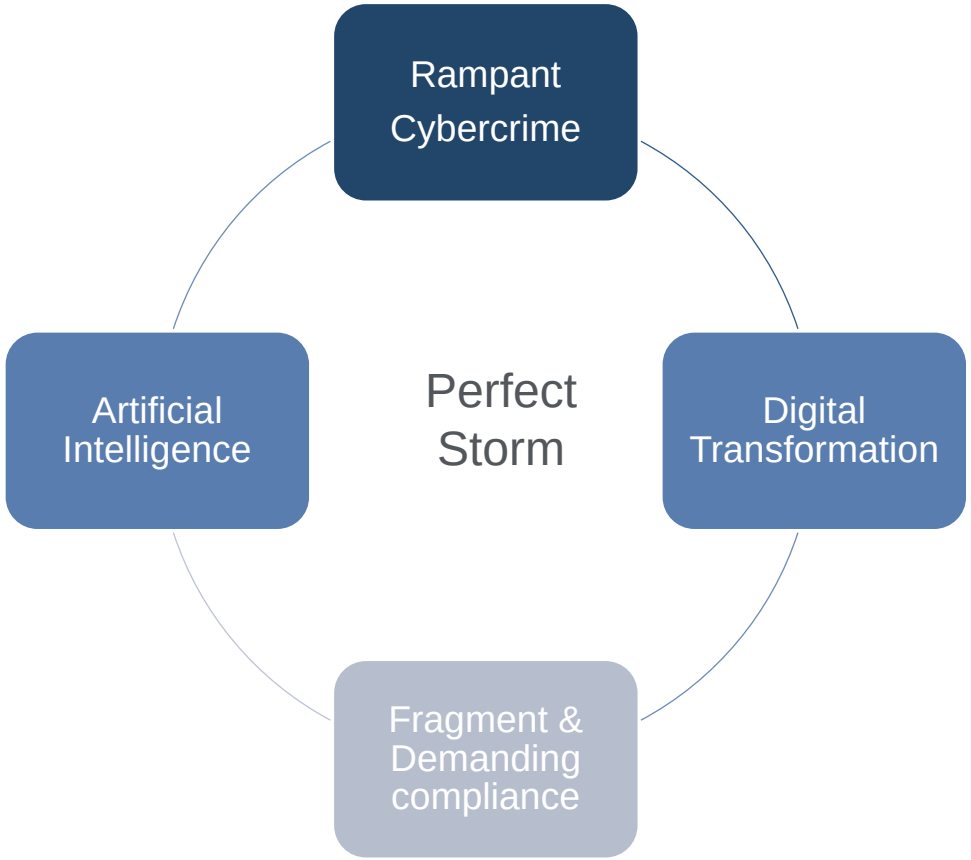
04 | Q&A

00 | INTRO AND CONTEXT

Perfect Storm
Context
Cyber risks in Hospitality
RHG IT Security Program

Perfect Storm

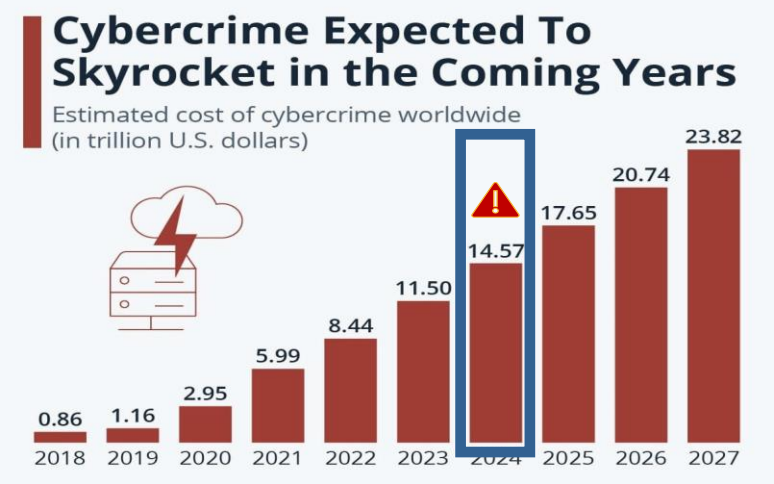
Competing force

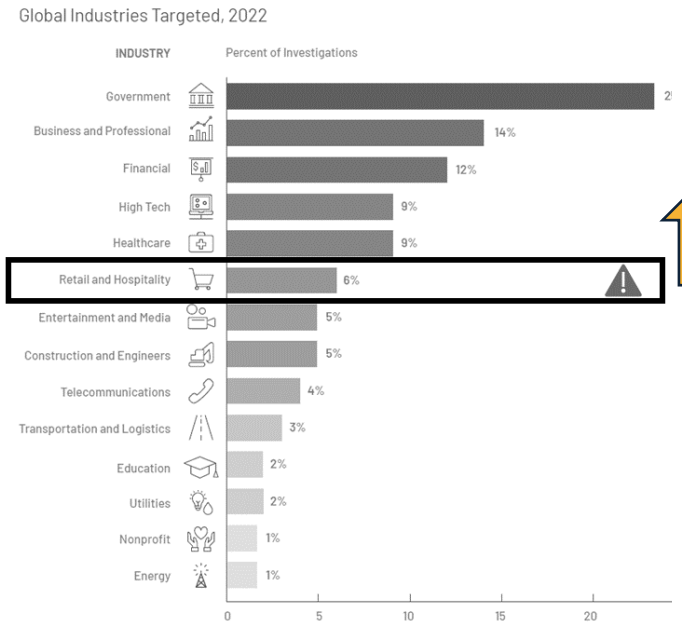


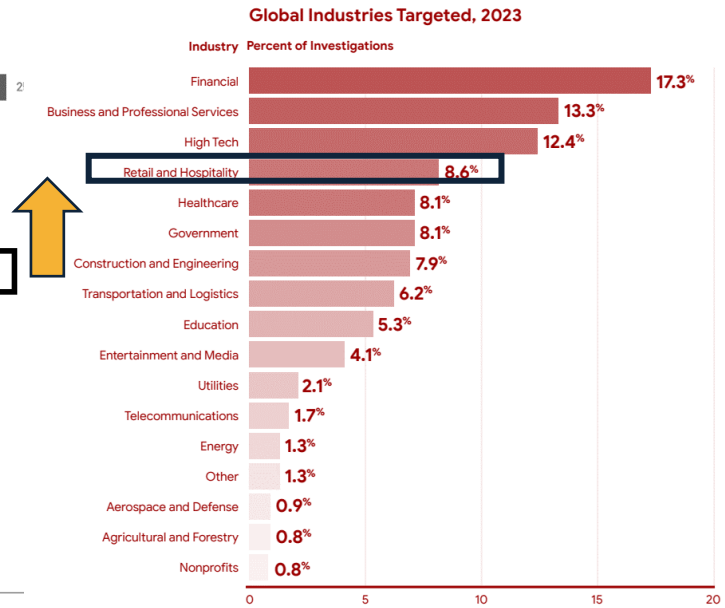
Context

Cybersecurity is a *$14.5* trillion business problem in 2024

Every 39 seconds, somewhere in the world, a cyber-attack occurs.





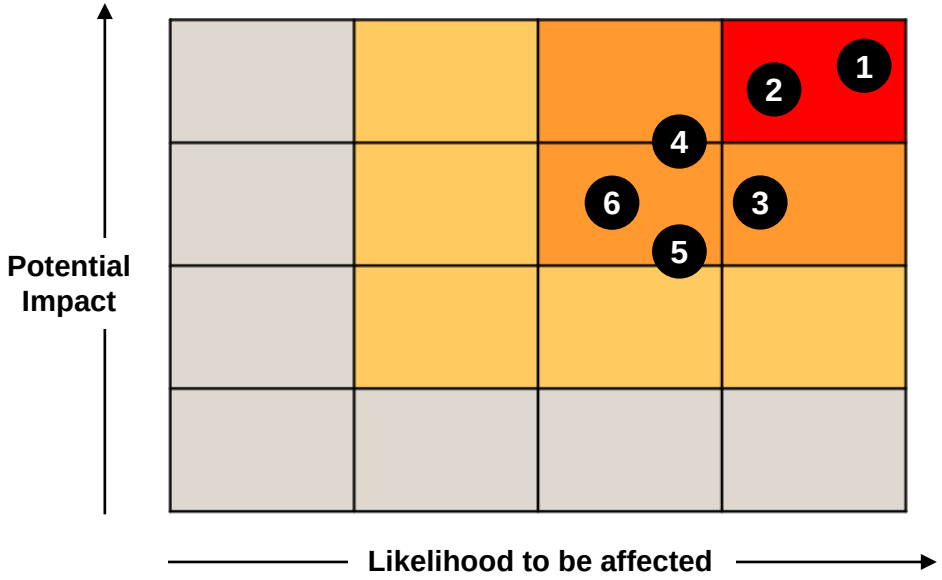


Initial Infection Vector (When Identified)

Cyber risks in Hospitality

These are the main Cyber risks that affect business such as RHG:

Hospitality – Inherent Risk Map



#	Threats	Potential impact
1	**Ransomware**	Typical ransom = **15M$** (ex: Caesars) Company at a stop for weeks. Total cost **25-100M**
2	**Data breaches**	Typical fraud costs = **2.7M$** High fines (Marriott recently: **19 M£**
3	**Insiders and fraud**	Data breach or boycott; industrial espionage; fraud (ex. Zendal **9M€**)
4	**Applications attacks (web, EMMA)**	Critical applications (EMMA, Web,…) down for weeks; Data breach.
5	**Attacks through 3rd Party and Shadow IT**	Services and applications down for days or weeks; data breaches.
6	**Data centers and Cloud vulnerabilities**	Systems down for hours or even days; Data breach.

RHG IT Security Program

RHG IT Security has identified critical digital assets to be protected by security systems. Response plans to cyber-incidents are documented and tested. Recovery situations tested regularly (e.g. ransomware), externally benchmarked yearly.

RHG has defined 5 critical Digital Assets categories to be protected in priority

1. Guests & Clients Data	Personal Data
	Payment Card Data
	Devices & Internet accounts
2. RHG Users Data	RHG VIP & Privileged users' data
	Employees Personal Information (PII, PHI)
3 Revenue Flow enablers	Website & Mobile Apps
	Marketing & Digital Platforms
	RHG IT Platform (EMMA, Channels,…)
4. Business Operations	Loyalty rewards information and credit
	Hotel Services and room stock
5. Business Information	Confidential Business info.
	Financial Exhibits & Status

Preventive Actions

IT Security program is protecting RHG assets against cyber-attackers.

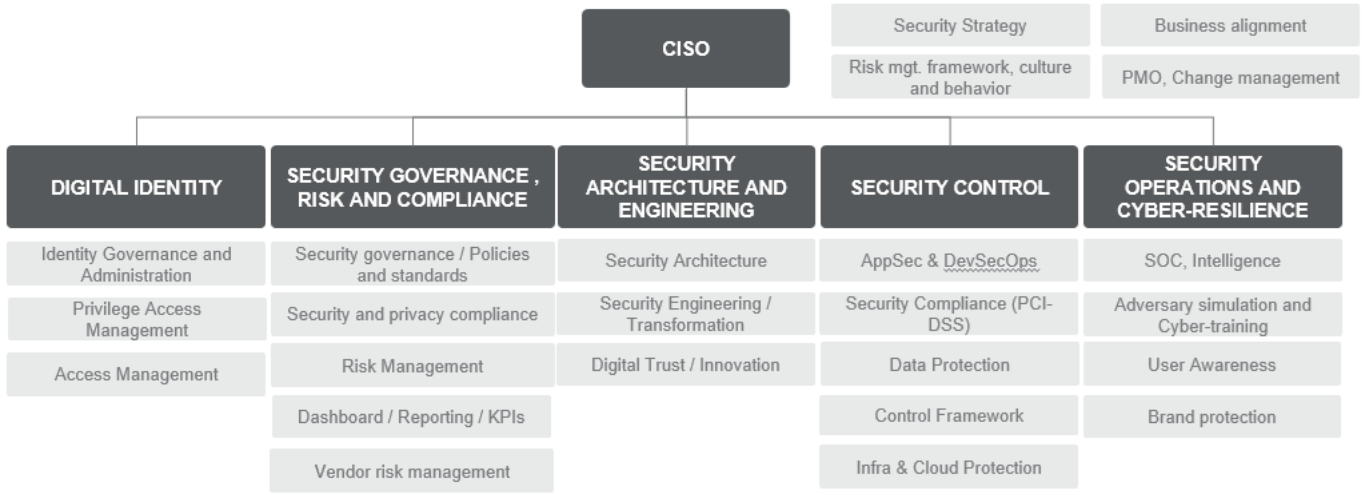
1. Digital Identity Security
2. Infrastructure & Cloud Security
3. Application Security
4. Data Security
5. Cyber defence
6. Compliance

Reactive Actions

Crisis management and recovery procedures are documented and tested.

- **Security Incident Response** plan fully documented, implemented and operational.
- **Crisis management plans** fully documented and tested on real scale

How we get organized

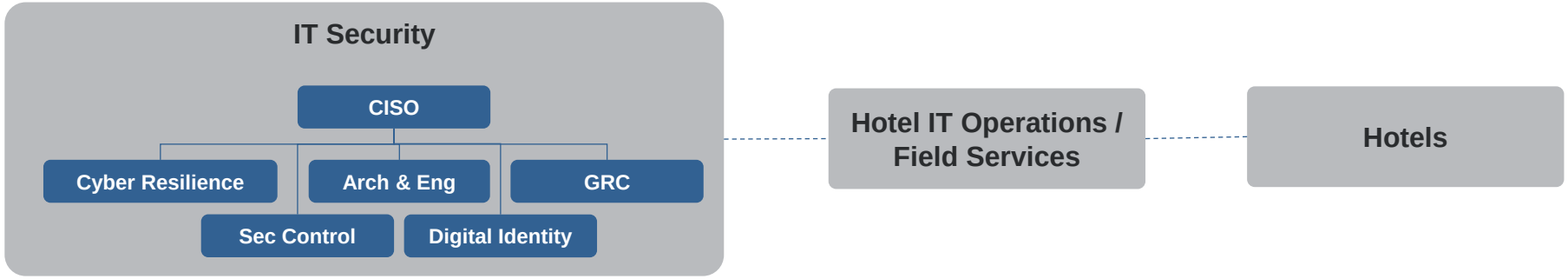


01 | STRATEGY AND GOVERNANCE

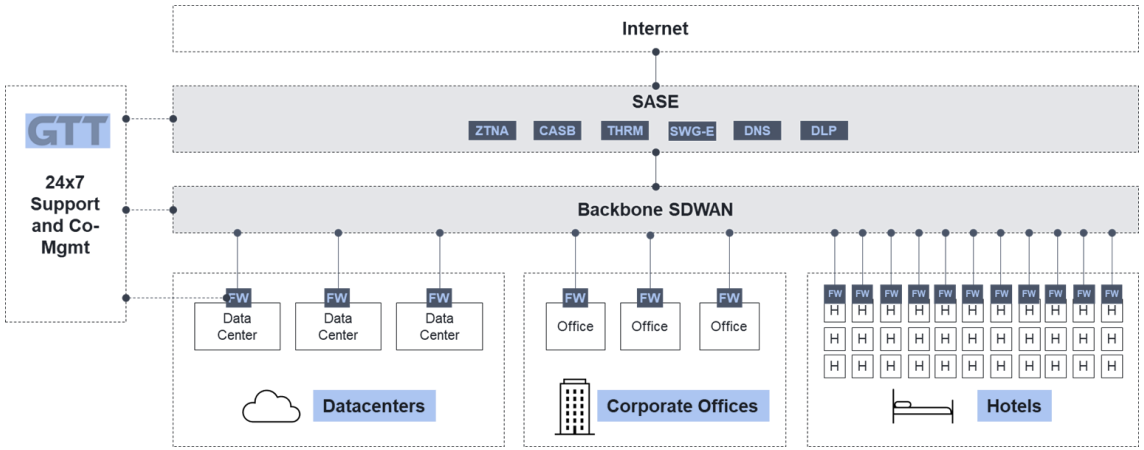
Governance model
People
IT Security Reporting

Governance: Central Services and Properties

Governance: Hotels



High Level Architecture



RHG can be understood as composed of three tiers:

- Central Services (DataCenters)
- Corporate Offices (ASO,CSO)
- Hotels

Governance: Lines of Defense (as we understand them)

1 APPLY CONTROLS

- Central Services IT
- Hotels IT
- Business
- Corporate Functions

2 CONTROL AND SUPERVISE

- **IT Security**
- ERM (nascent)
- Privacy
- Financial Control

3 INDEPENDENT ASSURANCE

- Internal Audit
- Fraud management

People

RHG understand that People represents a fair share of our Risk surface. In order to manage it, we carry out the following:

- **Policies:** 02.2 Acceptable Use Policy, 02.3 Mobile Device Policy, 02.4 Access to IT services for 3rd parties
- **Cybersecurity and privacy awareness yearly training**: e-Learning required for all employees and hotel staff at least on a yearly basis
- **Next-gen continuous user awareness** with shorter, more frequent and tailored training pills, coupled with simulated phishing campaigns, aimed at corporate users in Central Services
- **IT Consent management forms**: so that users agree to corporate secure usage rules of their corporate devices
- **Protecting RHG** website and brand

Cybersecurity Awareness

IT Consent Management

Next gen security awareness

Hotel Security Operations Reports

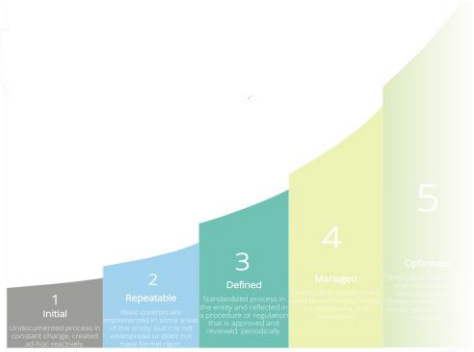
Identifying out current situation to guide our next steps…

IT Security Dashboard – Now with ASO/CSO information

Information Security Council Report

KRI Model		Risks											
		Ransomware	Data manipulation	Data Breach	Services Interruption	Compromised Systems	Reputation degradation	Account Takeover & Credential Stuffing	Fraud	DNS or web Spoofing	Compromised Systems: physical breach in Hotel	Data Center & Misconfigured
		R1	R2	R3	R4	R5	R6	R7	R8	R9	R10	R11
KPIs	Obs. Users	0	1	3	0	0	0	2	2	0	2	2
	Phish. Camp.	3	2	3	3	0	0	3	3	0	0	0
	Vulnerabiliti	4	3	4	4	4	0	0	3	0	3	3
	Obs. OS	4	3	4	4	4	4	0	4	0	4	4
	SOC incidents	3	1	3	3	3	0	0	2	0	2	2
	Falcon	3	2	3	3	3	0	0	3	0	3	0
	HaveIBeenPwnd	3	1	3	3	3	2	2	2	0	2	0
	Domains	0	0	0	0	0	3	0	3	3	3	0
Risk Level		4	3	4	4	4	4	1	4	1	4	4

Security Maturity Assessment



We use various KPIs to determine our next steps, each differentiated by service, TIER, and the level of risk we are willing to take. We use these KPIs to create:

- A governance process to use that information in order to launch tactical actions to decrease RHG exposure as a whole
- A strategic direction to progressively decrease risk and increase visibility

02 | CYBERSECURITY FUNCTIONS AND SERVICES

Operational Model

Function and Services

Function and Services

Security Front-Desk

How can we help you?

- HELP!! Cybersecurity incident
- Security in projects
- IT Security policies and standards
- Access into RHG Systems and Applications
- Learn about Cyber threats and how to stay secure
- IT Security resources for hotels
- RHG IT Security Advisories
- Office 365 (Rez-365) protection
- SSO / user management for applications

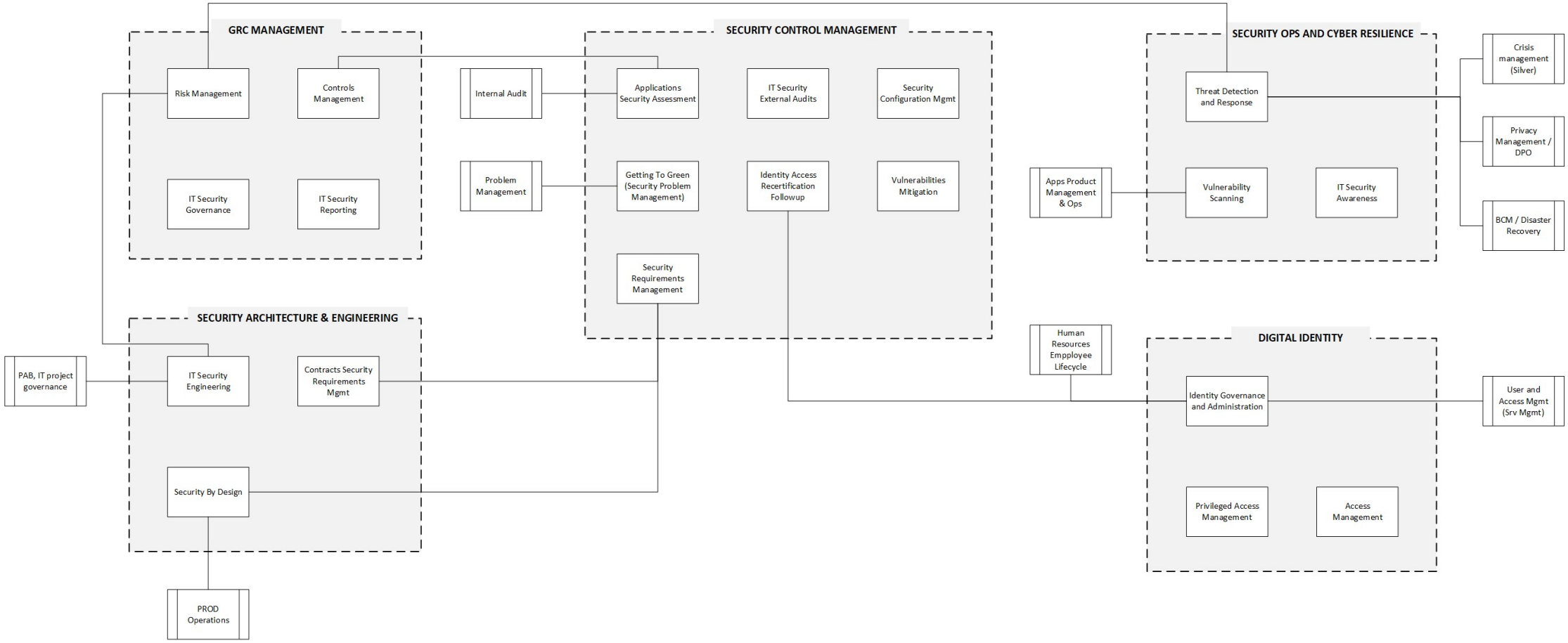
Service Catalogue

- Vendor assurance
- IT Security assessment of projects
- Application Security and DevSecOps
- Vulnerability Management
- PCI-DSS Compliance (Central Services)
- Phishing protection
- IT Security monitoring and incident management
- Managed Detection and Response (MDR)
- Cybersecurity Awareness and Training
- Brand and users identity protection
- SSO and Authentication Services
- Identity lifecycle management and users' account provisioning

protecting.radissonhotels.com

Operational Model

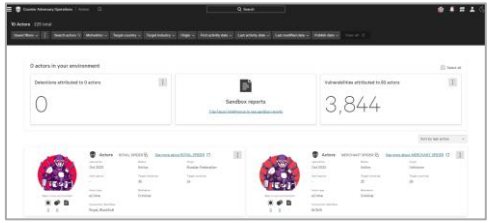
IT Security



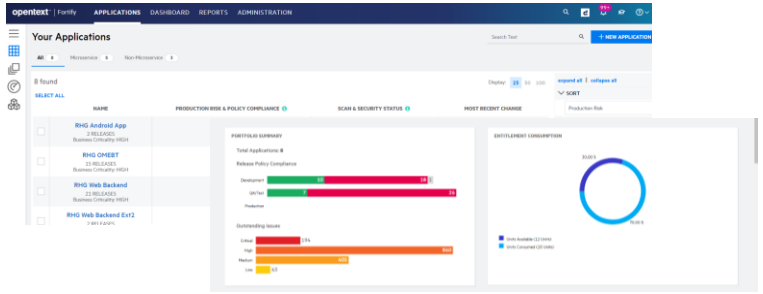
Function and Services

Behind the Scenes

Threat Detection & Response

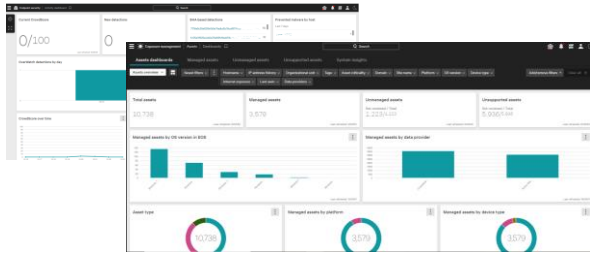


Custom Applications Security Assessment

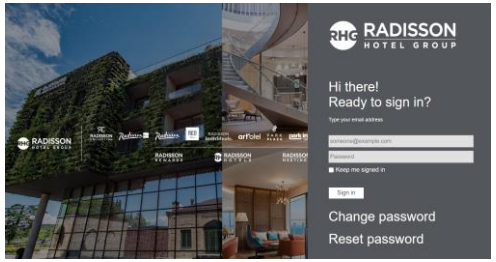


Pentesting

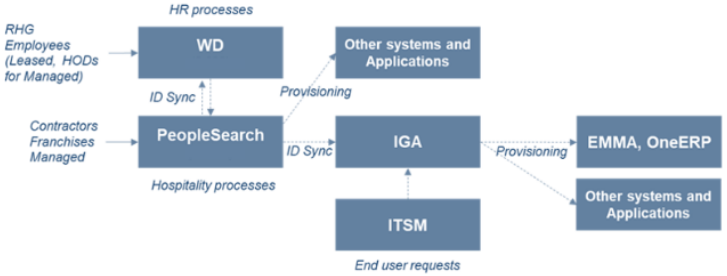
Vulnerability Management



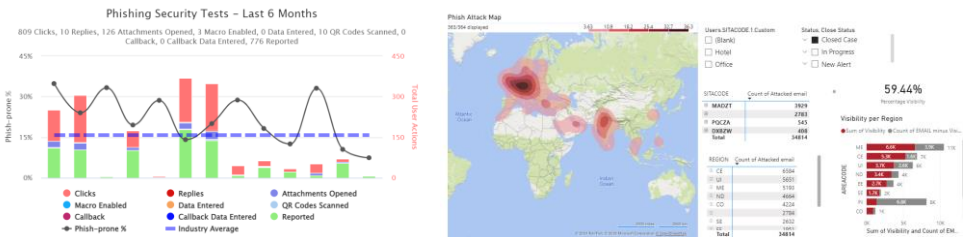
Access Management - SSO



IGA – Sailpoint Integrations



End user security awareness and phishing



03 | CYBERSECURITY CONTROLS

Prevention

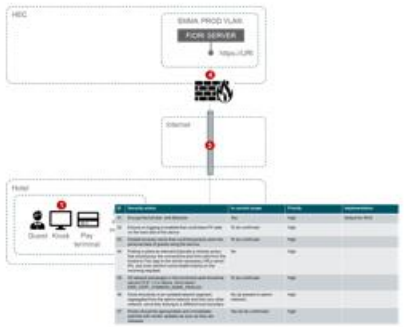
Detection

Response & Recovery

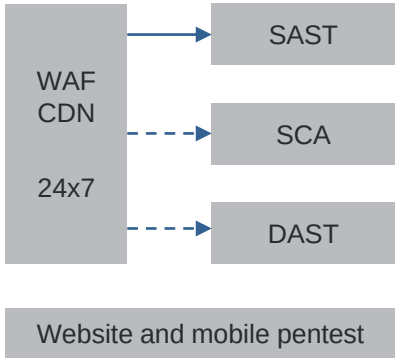
Prevention

Application

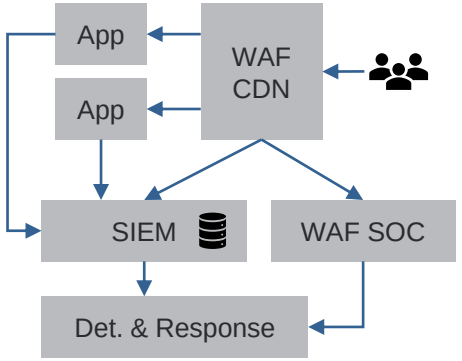
Security Req. Management



Application Sec Testing



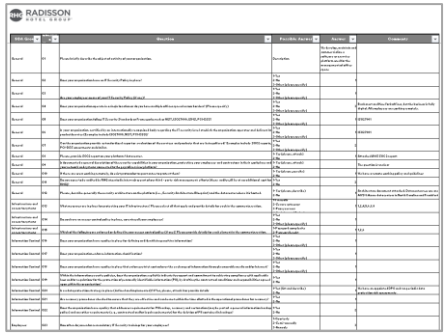
Application runtime protection



&

Third Party Risk

Vendor Assurance Form



Vendor Assurance Analysis

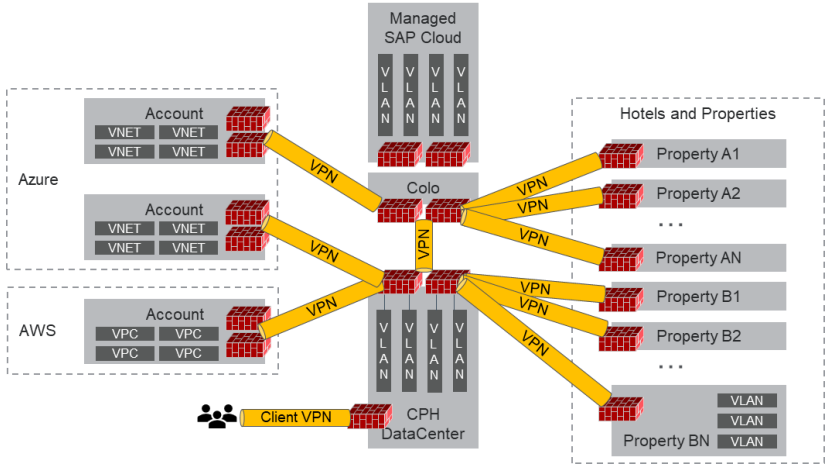
Vendor Assurance Registry

Prevention

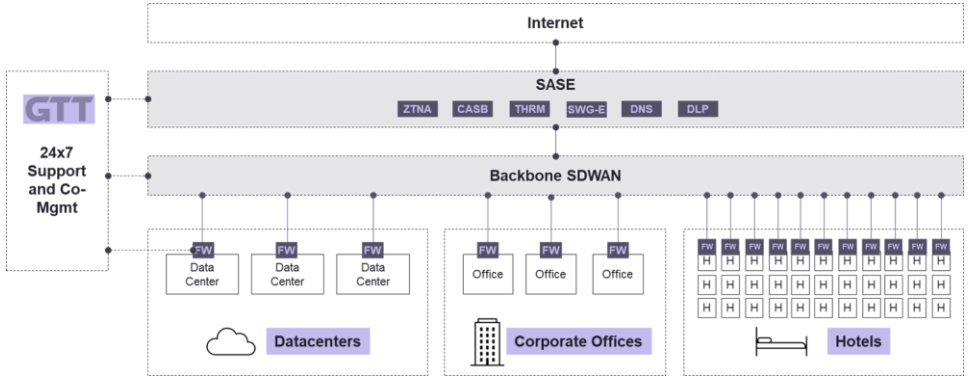
Architecture

Network Architecture

From a legacy network archiutecture…



To a modern, software defined and secure WAN:



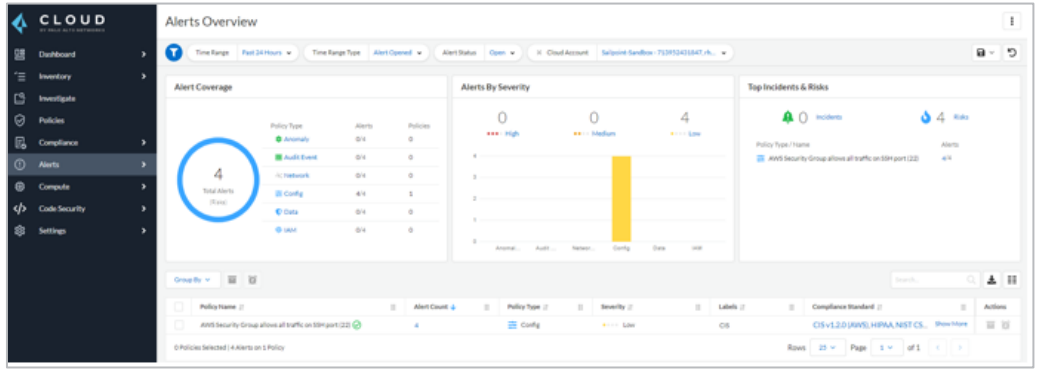
&

Cloud Security

Cloud Security Architecture, Posture Manager and Protection Platform

Cloud Security Reference Architecture

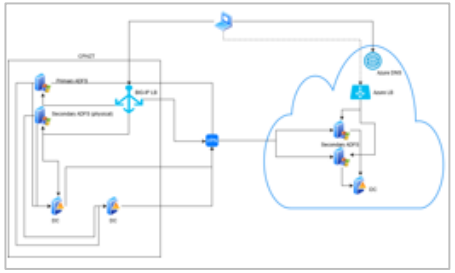
Cloud Security Platform: CSPM / CWPP



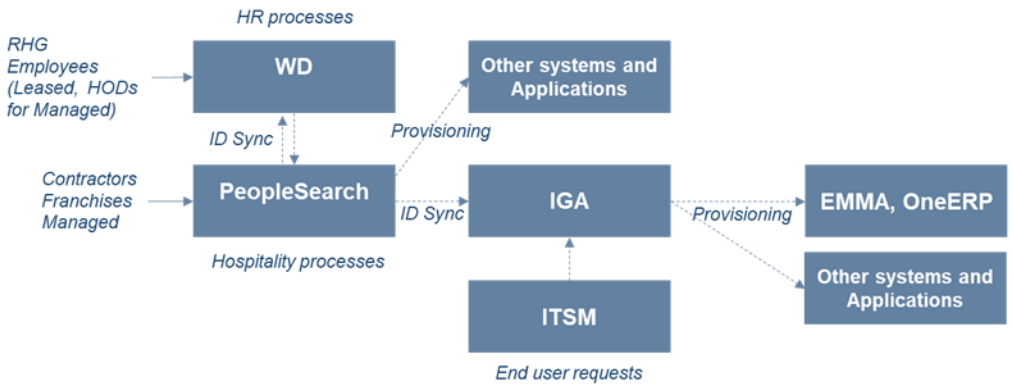
Prevention

Identity & Access

Access Management



Identity Management



We have our **Access Control Policy**, and approach IAM with the following capablities:

Access Management:

- For Authentication, we are integrating as many applications in our SSO IdP as possible, requiring MFA for all accesses
- Authorization policies exist within each application under the minimum privilege, need to know principles

Identity Lifecycle Management:

- **PeopleSearch** that reads RHG employees from Workday, allows for non-employees management, and can provision a number of services incl. AD, O365, as well as some corporate applications.
- **IGA system**: for SAP provisioning, which supports our Hospitality core application, EMMA. A complete provisioning matrix is used to keep access permissions structured over time.

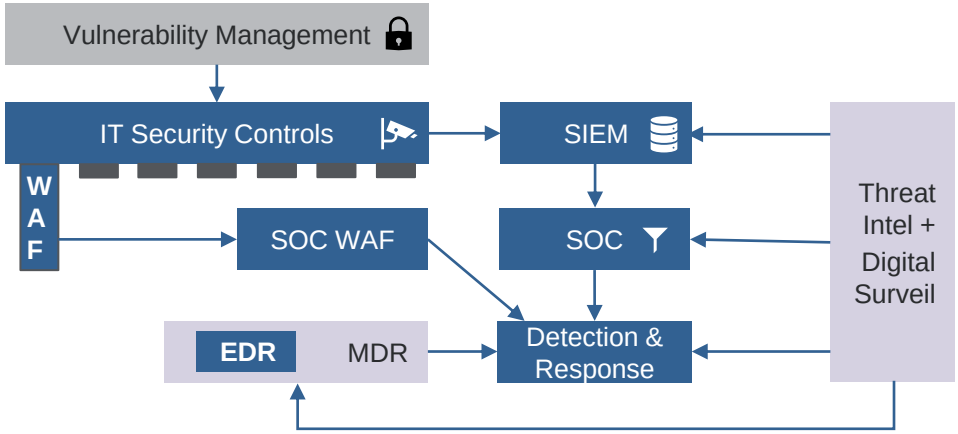
Detection

Cyberdefense Operation

- **Cyberdefense architecture**: vulnerability management, security controls, security monitoring (SIEM) and incident response
- **Security controls include**: firewalls+IPS, EPP, EDR, WAF, Active Directory / Sysmon, among others.
- **SOC**: leverages our SIEM and injects threat intelligence feeds in the analysis for the 24x7 security monitoring of our organization
- **WAF** : 24x7 service focused on Web attacks prevention, detection and response
- **MDR**: based on EDR agents + 24x7 detection and response services from an outsourced provider
- **Digital surveillance**: increased awareness of external threats like credentials leakage, domain squatting, dark web, data leaks…
- **Digital certificates surveillance**: discover and resolve exposed applications and weak certificates / cyphers

NEW

Cyberdefense Architecture



Hotels Security

- Hotels are required to monitor their own systems and report any incident or potential security concern immediately.
- They also get notifications from our central services should our SOC / SIEM raise alerts involving them.

Response and Recovery

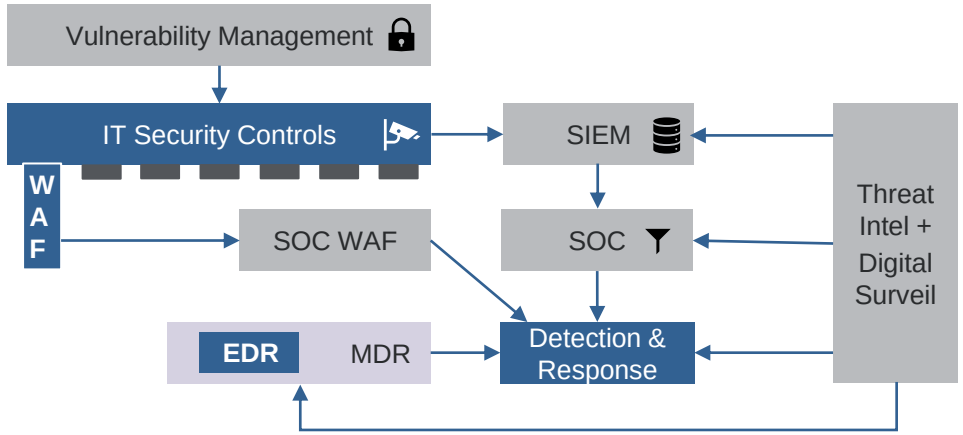
Incident Reponse

Incident response is also part of our **Cyberdefense architecture**:

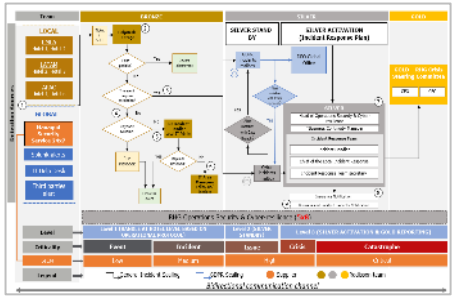
- As alerts are generated / raised from SOC, from SIEM, or from the properties themselves, the IT Sec Incident Response Plan is applied to them. Technically, the different controls are used to contain threats as they happen. Lessons learnt are part of the process in order to perform continuous improvement of our Cyberdefense processes.
- Our Incident Response Plan has two modes (central services and hotels) and three criticality levels (Bronze, Silver and Gold). It also includes a number of response playbooks according to different incident types.

Continuity-wise, we have a **Business Continuity Management Policy**, which establishes the requirements in terms of business continuity.

Cyberdefense Architecture



IT Sec Incident Response Plan



Hotels Security

- Hotels are responsible for managing and remediating incidents affecting their systems and networks, as per our Hotels Security Incident Response Process
- According to our policies, hotels are required to have a continuity plan and test it at intervals, for which RHG provides templates and guidance.
- This is part of IT audits on hotels.

LEARN TO GROW
academyonline.radissonhotels.com